

LEARNSPHERE EDTECH

NIST CYBERSECURITY FRAMEWORK (CSF) 2.0

Current-State Gap Assessment, Target Profile & Remediation Roadmap

Document Control	Details
Document ID	LS-NIST-CSF-GA-001
Version	1.0
Classification	Internal – Confidential
Status	Final – Simulated Hands-On GRC Assessment
Framework	NIST Cybersecurity Framework (CSF) 2.0
Assessment Type	Current Profile vs Target Profile Gap Assessment
Organization	LearnSphere EdTech
Prepared By	Mr. Meejan Shaikh – GRC Analyst
Reviewed By	Information Security Manager
Approved By	CISO

Portfolio / Simulation Notice

LearnSphere EdTech is a fictional organization. Current-state practices, evidence assumptions, gaps and remediation actions are simulated for hands-on GRC learning and must not be represented as a real certification, compliance assessment or independent audit.

1. Executive Summary

This report presents a simulated NIST Cybersecurity Framework (CSF) 2.0 gap assessment for LearnSphere EdTech, a fictional cloud-based EdTech organization providing a Learning Management System (LMS) to schools. LearnSphere uses AWS as its primary cloud hosting environment and processes sensitive student and academic information, including information relating to minors.

The assessment assumes that LearnSphere already has basic and partially documented cybersecurity practices. The objective is therefore to assess the current cybersecurity posture, define a target state, identify gaps and establish a risk-prioritized remediation roadmap rather than build a security program from zero.

The assessment gives particular attention to GOVERN and IDENTIFY gaps concerning children's-data governance, parental consent and data minimization, and PROTECT gaps concerning access controls for student records. DETECT, RESPOND and RECOVER are also reviewed at a scoped level.

Overall Assessment Conclusion

LearnSphere has a developing cybersecurity foundation, but material improvement is required in children's-data governance, data minimization, periodic student-record access reviews, privileged access/MFA, monitoring assurance and measurable cybersecurity oversight.

2. Assessment Purpose

The purpose is to establish a Current Organizational Profile, define a Target Organizational Profile, compare the two, prioritize material gaps and provide management with an actionable improvement roadmap.

- Establish current cybersecurity outcomes using the NIST CSF 2.0 structure.
- Define target outcomes appropriate to LearnSphere's business and risk profile.
- Identify and document gaps between current and target states.
- Prioritize gaps using business impact, data sensitivity, risk and implementation effort.
- Assign accountable owners and target remediation periods.
- Provide a management-ready cybersecurity improvement roadmap.

3. Assessment Scope

Scope Area	Included
Organization	LearnSphere EdTech; approximately 150–250 employees
Business Service	Cloud-based Learning Management System for schools
Cloud Environment	AWS-hosted production and supporting environments
Information	Student personal data, academic records, account information and security logs
Identity & Access	Application users, administrators, privileged accounts and AWS IAM
Governance	Cybersecurity governance, risk ownership, policies and oversight
Privacy Focus	Children's data, parental consent, data minimization and retention

Scope Area	Included
Security Operations	Logging, monitoring, incident response and recovery
Third Parties	Material suppliers and service providers supporting the LMS

Out of scope: customer-owned school infrastructure, unrelated personal systems and systems with no material connection to the LearnSphere LMS or the protection of in-scope information.

4. Assessment Objectives

- Assess selected cybersecurity outcomes across all six NIST CSF 2.0 Functions.
- Determine current implementation state using simulated evidence and documented assumptions.
- Identify high-priority gaps affecting student/minors' data and access control.
- Define target outcomes for a mature, measurable cybersecurity posture.
- Develop accountable remediation actions and timelines.

5. Standard and Reference Basis

Reference	Application
NIST CSF 2.0	Primary framework for cybersecurity outcomes, Organizational Profiles and assessment structure.
NIST SP 1301	Guidance for creating and using Current and Target Organizational Profiles.
NIST SP 1302	Reference for CSF Tiers and rigor of cybersecurity risk governance/management.
ISO/IEC 27001:2022	Contextual reference from LearnSphere Project 1; not the primary assessment framework.
India DPDP Act	Regulatory context for the fictional organization's personal-data and minors' data risk considerations.

NIST CSF 2.0 is outcome-based and organizes cybersecurity outcomes under six concurrent Functions: Govern, Identify, Protect, Detect, Respond and Recover. It does not prescribe one implementation method.

6. Assessment Methodology

Phase	Activity	Output
1	Define scope and business context	Assessment scope and assumptions
2	Establish Current Profile	Current-state assessment
3	Define Target Profile	Target-state outcomes
4	Compare profiles	Gap register
5	Prioritize	P1–P4 priorities
6	Plan remediation	Roadmap, owners and dates
7	Management reporting	Executive conclusion and next actions

6.1 Internal Scoring Scale

Important

The 0–4 scale is an internal scoring mechanism created for this portfolio project. It is not an official NIST maturity score. NIST CSF 2.0 uses outcomes, Organizational Profiles and CSF Tiers.

Score	State	Definition
0	Not Implemented	No meaningful evidence the outcome is addressed.
1	Initial / Ad Hoc	Informal or inconsistent practices exist.
2	Developing	Some defined practices exist but implementation is inconsistent or incomplete.
3	Defined / Managed	Documented and generally implemented with assigned ownership.
4	Measured / Optimized	Consistently implemented, measured, reviewed and improved.

7. Current-State Assumptions

Domain	Assumed Current Practice	Primary Concern
Asset Management	Basic inventory exists.	Lifecycle validation and ownership need discipline.
AWS Security	Baseline IAM and cloud security settings exist.	Privileged access and configuration assurance need strengthening.
User Access	Documented but inconsistent provisioning.	Access review and least privilege are inconsistent.
MFA	Enabled for some administrative users.	Uniform privileged-access enforcement is not established.

Domain	Assumed Current Practice	Primary Concern
Data Governance	Student data is recognized as sensitive.	Purpose, minimization and retention need formalization.
Children's Data	Some privacy safeguards exist.	Parental-consent governance is not consistently evidenced.
Monitoring	Cloud/application logs are available.	Monitoring coverage and review are developing.
Incident Response	Informal handling exists.	Playbooks, escalation and testing need formalization.
Recovery	AWS backups exist.	Recovery objectives and testing need stronger evidence.

8. Current Organizational Profile

CSF Ref.	Area	Current	Assessment
GV.OC	Organizational Context	2	Context understood; children's-data requirements not consistently translated into security requirements.
GV.RM	Risk Management	2	Risk practices exist; metrics and enterprise integration are developing.
GV.RR	Roles & Responsibilities	2	Roles exist; children's-data accountability needs clearer ownership.
GV.PO	Policy	2	Core policies exist; minimization/consent requirements need explicit treatment.
GV.OV	Oversight	1	Management reporting lacks mature cybersecurity KPIs/KRIs.
GV.SC	Supply Chain	2	Vendor risk recognized; assurance evidence and review cadence need improvement.
ID.AM	Asset Management	3	Asset register exists; ongoing lifecycle validation is required.
ID.RA	Risk Assessment	3	Risk register and treatment methodology established.
ID.IM	Improvement	2	Improvement occurs but measurement is developing.
PR.AA	Identity & Access	1	Periodic reviews, least privilege and privileged access are inconsistent.
PR.DS	Data Security	2	Protection exists; children's-data minimization and retention need formalization.
PR.PS	Platform Security	2	AWS controls exist; secure configuration assurance needs strengthening.
PR.IR	Infrastructure Resilience	2	Backups exist; resilience testing needs improvement.
DE.CM	Continuous Monitoring	2	Logging exists; monitoring coverage and metrics are developing.
DE.AE	Adverse Event Analysis	2	Alert investigation exists; formal triage criteria are limited.
RS.MA	Incident Management	2	Basic handling exists; playbooks and escalation need strengthening.
RS.CO	Incident Communication	2	Communication exists informally; escalation paths need documentation.
RS.AN	Incident Analysis	2	Logs can support investigation; formal procedures are developing.
RS.MI	Incident Mitigation	2	Basic response exists; technical playbooks need expansion.
RC.RP	Recovery Planning	2	Backups exist; recovery procedures/testing need improvement.
RC.CO	Recovery Communication	2	Communication possible but not consistently exercised.
RC.IM	Recovery Improvement	1	Formal lessons-learned process is immature.

9. Target Organizational Profile

CSF Ref.	Area	Target	Target-State Expectation
GV.OC	Organizational Context	3	Children's-data obligations and stakeholder expectations formally translated into security requirements.
GV.RM	Risk Management	3	Risks consistently assessed, owned, prioritized and reported.
GV.RR	Roles & Responsibilities	3	Security/privacy accountability for student data formally assigned.
GV.PO	Policy	3	Policies explicitly address children's data, access, minimization and retention.
GV.OV	Oversight	3	Management receives regular cybersecurity KPI/KRI reporting.
GV.SC	Supply Chain	3	Critical suppliers are risk-assessed, contractually governed and reviewed.
ID.AM	Asset Management	4	Critical assets, data, owners and dependencies are maintained and validated.
ID.RA	Risk Assessment	3	Risk assessment is repeatable and linked to business impact.
ID.IM	Improvement	3	Audits, metrics and lessons learned drive tracked improvement.
PR.AA	Identity & Access	4	Least privilege, MFA, RBAC, privileged access and periodic reviews are consistently implemented.
PR.DS	Data Security	4	Student data is classified, minimized, retained, protected and securely disposed.
PR.PS	Platform Security	3	Cloud/application platforms use secure baselines and vulnerability/change management.
PR.IR	Infrastructure Resilience	3	Backup/recovery capabilities are tested against defined objectives.
DE.CM	Continuous Monitoring	3	Critical AWS, application and identity events are centrally monitored.
DE.AE	Adverse Event Analysis	3	Alerts are triaged using documented criteria and escalation.
RS.MA	Incident Management	3	Incident playbooks and escalation procedures are documented and tested.
RS.CO	Incident Communication	3	Internal/customer/regulatory communication roles are defined.
RS.AN	Incident Analysis	3	Investigations preserve evidence and determine root cause/impact.
RS.MI	Incident Mitigation	3	Containment and eradication procedures exist for priority scenarios.
RC.RP	Recovery Planning	3	Recovery plans are documented, tested and business-aligned.
RC.CO	Recovery Communication	3	Recovery communications are planned and exercised.
RC.IM	Recovery Improvement	3	Lessons learned are formally tracked to closure.

10. NIST CSF 2.0 Gap Register

ID	CSF	Gap	Score	Risk	Priority	Owner
G01	GV.OC/GV.PO	Children's-data requirements not consistently translated into formal security/privacy requirements.	2→3	High	P1	CISO / InfoSec Manager

INFORMATION SECURITY MANAGEMENT SYSTEM
(ISMS)

DOCUMENT ID: LS-NIST-CSF-GA-001

VERSION: 1.0

INTERNAL – CONFIDENTIAL

ID	CSF	Gap	Score	Risk	Priority	Owner
G02	GV.OV	Management reporting lacks cybersecurity KPIs/KRIs for student-data protection and remediation.	1→3	Medium	P2	InfoSec Manager
G03	GV.SC	Critical supplier cybersecurity assurance is not consistently evidenced.	2→3	High	P2	Vendor / Procurement Owner
G04	ID.RA	Risk metrics and trend reporting are developing.	3→3	Medium	P3	GRC Analyst
G05	ID.AM/PR.DS	Student-data inventory needs stronger linkage to purpose, retention and minimization.	3→4	High	P1	Data / Security Owner
G06	PR.AA	Periodic student-record access reviews are not consistently evidenced.	1→4	Critical	P1	IAM Owner
G07	PR.AA	Privileged access and MFA are not uniformly standardized.	1→4	Critical	P1	Cloud Security / IAM
G08	PR.DS	Data minimization is not consistently enforced at application-field level.	2→4	High	P1	Product Security / Data Owner
G09	PR.DS	Retention and secure deletion need stronger operational evidence.	2→4	High	P2	Data Owner
G10	PR.PS	AWS secure configuration assurance needs standardized baselines and validation.	2→3	High	P2	Cloud Security Owner
G11	DE.CM	Monitoring coverage and alert review are not consistently measured.	2→3	High	P2	Security Operations
G12	DE.AE/RS.AN	Incident triage and investigation criteria need standardization.	2→3	Medium	P3	Security Operations
G13	RC.RP	Recovery testing is not sufficiently evidenced against defined objectives.	2→3	High	P2	IT Operations
G14	RC.IM	Formal recovery lessons-learned tracking is immature.	1→3	Medium	P3	BCP / Security Manager

11. Priority Focus — Children's Data & Student Records

Ref.	Focus	CSF Area	Assessment Finding	Risk	Priority
F01	Parental Consent	GV.OC/GV.PO	Consent requirements and evidence are not consistently embedded in relevant workflows.	High	P1
F02	Data Minimization	PR.DS/ID.AM	Student attributes are not consistently mapped to documented business purpose.	High	P1
F03	Student Record Access	PR.AA	Periodic access certification is not consistently evidenced.	Critical	P1

DOCUMENT ID: LS-NIST-CSF-GA-001 | VERSION: 1.0

INTERNAL – CONFIDENTIAL

Ref.	Focus	CSF Area	Assessment Finding	Risk	Priority
F04	Privileged Access	PR.AA	MFA and privileged-access controls are not uniformly enforced.	Critical	P1
F05	Retention / Deletion	PR.DS	Retention schedules and deletion evidence require formalization.	High	P2

12. Gap Prioritization Method

Priority	Criteria	Management Expectation
P1 – Critical	Sensitive student data, privileged access, high impact, regulatory exposure or material likelihood.	Immediate action and executive visibility; generally 0–90 days.
P2 – High	Material cybersecurity exposure requiring structured remediation.	Plan and execute generally within 90–180 days.
P3 – Medium	Important maturity improvement with manageable exposure.	Plan generally within 180–270 days.
P4 – Low	Limited immediate risk or optimization opportunity.	Normal improvement backlog.

13. Remediation Roadmap

Timeline	Pri.	Action	Owner	Outcome
0–30 days	P1	Confirm children's-data governance requirements and assign accountable owners.	CISO / InfoSec	Governance baseline established.
0–30 days	P1	Inventory privileged accounts and enforce MFA for administrative access.	IAM / Cloud Security	Privileged-access exposure reduced.
31–60 days	P1	Complete student-record access certification across LMS and AWS-integrated systems.	IAM / Data Owners	Excess access removed.
31–60 days	P1	Complete student-data field inventory and minimization review.	Data / Product Security	Unnecessary collection removed/restricted.
61–90 days	P1	Implement parental-consent evidence requirements in applicable workflows.	Product / Privacy / Security	Consent becomes traceable.
61–90 days	P2	Define retention and secure-deletion schedule.	Data Owner	Retention operationalized.
91–180 days	P2	Implement AWS secure configuration baseline and compliance validation.	Cloud Security	Cloud assurance improved.
91–180 days	P2	Improve monitoring coverage, alert SLAs and reporting.	Security Operations	Detection becomes measurable.
91–180 days	P2	Define/test RTO/RPO and recovery exercises.	IT Operations	Recovery readiness demonstrated.
181–365 days	P3	Establish KPI/KRI dashboard and annual NIST profile refresh.	InfoSec Manager	Continuous governance established.

14. Recommended Cybersecurity KPIs / KRIs

Metric	Definition	Suggested Target
Privileged MFA Coverage	% of privileged accounts protected by MFA	100%
Student Data Access Review	% of in-scope access certified on schedule	100% quarterly
Excess Access Findings	Inappropriate/excess permissions found during review	Downward trend; no overdue critical items
Children's Data Inventory	% of data stores mapped to owner, purpose and retention	100%
Data Minimization Exceptions	Approved exceptions to minimum-data collection	Tracked and declining
Security Monitoring Coverage	% of critical systems sending security-relevant logs	≥95%
High-Risk Gap Aging	P1/P2 gaps overdue against target date	Zero overdue P1
Recovery Test Success	% of scheduled recovery tests meeting objectives	100% planned tests

15. Assessment Conclusion

LearnSphere has a useful cybersecurity foundation, particularly in asset management, risk assessment and basic cloud/security operations. The posture is not yet consistently governed or measured across the areas most critical to its risk profile.

The highest-priority improvements are children's-data governance, data minimization, student-record access reviews and privileged access/MFA. These should receive management attention because a compromise could expose sensitive information relating to minors and materially affect business, privacy and regulatory risk.

The roadmap follows a practical sequence: establish governance and address immediate privileged-access exposure; strengthen data governance and access certification; then improve cloud configuration assurance, monitoring, recovery testing and management metrics.

16. Evidence Collection Plan

Evidence Domain	Examples	CSF Areas
Governance	Policies, privacy requirements, risk reports, management minutes	GV.OC, GV.RM, GV.PO, GV.OV
Children's Data	Data inventory, data flows, consent process, retention schedule	GV.OC, GV.PO, ID.AM, PR.DS
Identity & Access	IAM export, RBAC matrix, MFA report, access-review evidence	PR.AA
Cloud Security	AWS configuration reports, baselines, security findings	PR.PS, PR.IR
Monitoring	SIEM/log-source inventory, alerts, dashboards	DE.CM, DE.AE
Incident Response	Incident register, playbooks, exercise reports	RS.MA, RS.CO, RS.AN, RS.MI
Recovery	Backup reports, recovery plans, RTO/RPO and test results	RC.RP, RC.CO, RC.IM
Third Parties	Vendor assessments, contracts and security questionnaires	GV.SC

17. GRC Traceability to Project 1

Project 1 Artifact	Use in NIST CSF 2.0 Assessment
Organizational Context	Provides business, stakeholder and regulatory context for Current/Target Profiles.
Asset Register	Supports ID.AM and identification of critical assets/data.
Risk Register	Supports risk-based prioritization of NIST CSF gaps.
Statement of Applicability	Provides evidence of existing security treatment activities.
Internal Audit Report	Provides simulated evidence of control effectiveness and improvement needs.
Corrective Action / Management Review	Provides improvement-cycle evidence and informs the target state.

18. Approval & Sign-Off

Role	Name	Signature	Date
Prepared By	Mr. Meejan Shaikh – GRC Analyst		
Reviewed By	Information Security Manager		
Approved By	CISO		

20. Document Notes

This document is a simulated hands-on GRC deliverable prepared for portfolio and learning purposes. Current-state scores, evidence assumptions, gaps, priorities, owners and target dates are illustrative. A real assessment would require objective evidence, stakeholder interviews, configuration review and formally approved assessment criteria. The internal 0–4 scoring scale is used only to make this portfolio assessment measurable. It must not be presented as an official NIST CSF maturity rating. NIST CSF 2.0 provides the Core outcomes, Organizational Profiles and Tiers; organizations determine how these are applied to their own risk-management context.